



המכללה האקדמית תל אביב יפו
בית הספר למערכות מידע

אבטחת מידע ממוחשב - סייבר, 272035
ד"ר יצחק אביב
תשפ"ה, סמסטר א', מועד א', 17/02/2025

--	--	--	--	--	--	--	--	--	--

מספר זהות:

משך הבחינה: שעה וחצי
ללא חומר עזר

בבחינה 20 שאלות, יש לענות על כולן. משקל השאלות זהה - 5 נקודות לשאלה.
בכל שאלה יש לסמן את התשובה הנכונה ביותר (אחת בלבד).

בהצלחה!



שאלה מס' 1 (5 נק')

מהו ההבדל המרכזי בין "אינטרנט" לבין "מרחב הסייבר" (Cyber Space) ?

- "אינטרנט" מתייחס לרשתות המחוברות זה לזה, ו"סייבר ספייס" כולל גם רשתות מנותקות, התקני קצה ותהליכי שליטה ובקרה פיזיים.
- "אינטרנט" כולל רק אתרים ממשלתיים, בעוד "סייבר ספייס" כולל גם אתרים מסחריים.
- "סייבר ספייס" עוסק רק באבטחת מידע, בעוד "אינטרנט" עוסק בטכנולוגיה כללית.
- אין שום הבדל – שני המונחים מתארים בדיוק את אותו הדבר.
- "סייבר ספייס" הוא מונח טכני בלבד, ואילו "אינטרנט" מבטא מושג שיווקי למשתמשי קצה.

שאלה מס' 2 (5 נק')

במודל אבטחה מסורתי מבוסס פרימטר ארגון מיישם חומת אש (Firewall) סביב הרשת וסומך כי מה שבתוכה בטוח. כיום הדבר כבר לא מספיק. מהו אחד האתגרים העיקריים שגרמו צמצום חשיבות של מודל ה-Perimeter הקלאסי?

- ריבוי משתמשים ושותפים שמתחברים מרחוק, המייצרים "פרימטר" נייד שאינו סגור מאחורי חומות אש פנימיות.
- ירידה בעלויות תחזוקת חומות אש.
- אי-צורך בארכיטקטורת הגנה עקב מעבר לאפליקציות בענן.
- איסור רגולטורי לשימוש ב-VPN ברשתות ארגוניות.
- מעבר גורף לטלפונים חדישים מדור 5 שתומכים בפתרונות מודרניים.

שאלה מס' 3 (5 נק')

בנק גדול מקבל תלונה מלקוחות על העברות כספים שלא ביצעו. בחקירה ראשונית מתגלה שכל ההעברות:

- בוצעו מאותו אזור גיאוגרפי של הלקוחות
- עברו אימות דו-שלבי תקין
- התבצעו בשעות פעילות סבירות
- הסכומים היו בטווח הגיוני
- התבצעו במקביל למספר חשבונות שונים

מה הכי סביר שהתרחש?

- התוקפים ביצעו מתקפת Real-Time Phishing שכללה יירוט והעברה בזמן אמת של קודי האימות הדו-שלבי.
- התקפת מניעת שירות על מערכות ניטור של הבנק.
- התקפת Man in the Middle קלאסית על תקשורת ה-WiFi.
- זיוף תעודות דיגיטליות של הבנק.
- מתקפה מבוססת Malware על אפליקציית הבנק בטלפונים הניידים של הלקוחות.

שאלה מס' 4 (5 נק')

כיצד ניתן להבחין בין התקפת "יירוט" (Interception) לבין התקפת "זיוף" (Falsification), ומהן ההשלכות הארגוניות של כל סוג?

- יירוט מתמקד בגישה למידע, בעוד זיוף משנה את המידע.
- יירוט כולל גישה פיזית למערכת, בעוד זיוף מבוסס על שינויים בקוד.
- יירוט מבוסס על תקשורת רשתית, בעוד זיוף מתרחש בתוך מערכת מקומית בלבד.
- זיוף תלוי בכניסה לא מורשית לרשת.
- יירוט וזיוף הם תהליכים זהים מבחינת ההשפעה הארגונית.



שאלה מס' 5 (5 נק')

כיצד השימוש בתולעת ברשת ארגונית מנצל את חולשת שכבת הרשת, ומהם הכלים הטכנולוגיים שיכולים למנוע את התקיפה?

- א. התולעת משתמשת בהרשאות רשת לגיטימיות כדי להדביק מערכות נוספות.
- ב. תולעת זקוקה לקובץ ביצוע בלבד, ולכן מספיקה אנטי-וירוס.
- ג. התולעת מנצלת את מערכת אנטי וירוס הלא יעילה ברשתות.
- ד. מערכות חומת אש מונעות כל התפשטות תולעת ברשת.
- ה. תולעת מתבססת על סיסמאות חלשות בלבד.

שאלה מס' 6 (5 נק')

במהלך מתקפת סייבר על חברת אנרגיה, התוקפים:

- שינו ערכים במערכת הבקרה
- לא השביתו מערכות
- לא גנבו מידע
- ביצעו שינויים קטנים בלבד

מה המטרה הסבירה של התוקפים?

- א. הכנת תשתית למתקפה עתידית.
- ב. בקשת כופר להחזר הערכים לערכים מקוריים.
- ג. איסוף מידע על המערכות חברת אנרגיה.
- ד. גרימת נזק תדמיתי לחברת אנרגיה.
- ה. מיפוי מערכות דיגיטל בארגון.

5 השאלות הבאות מתייחסות לנתונים הבאים:

בבנק דיסקונט החליטו להרחיב את שירותיהם הדיגיטליים ולהקים תשתית שתאפשר ללקוחות לבצע פעולות בנקאיות מרחוק באופן מאובטח. לשם כך, מנהלי הסייבר של הבנק בנו ארכיטקטורה שבה הוקם אזור DMZ ייעודי. בין השאר, הבנק מנהל חיבורי רשת לשותפים עסקיים שאינם חשופים לאינטרנט. על אף הארכיטקטורה הזאת, מנהלי הסייבר מודעים לכך ששום פתרון אינו מושלם. הם יודעים כי ייתכן שהאקרים (תוקפים במרחב הסייבר) ינצלו חולשות בקונפיגורציית חומת האש (FW), או יצליחו לעקוף את מערכות הניטור והסינון.

שאלה מס' 7 (5 נק')

מדוע מנהלי הסייבר של בנק דיסקונט בוחרים לחבר את הרשת של השותפים העסקיים דרך ה DMZ גם אם אותה רשת לא מחוברת ישירות לאינטרנט?

- א. משום שהבנק אינו שולט ואינו מנטר את האופן שבו רשת הפרטנר מוגנת, ולכן מתייחס אליה כאל סיכון.
- ב. כדי להפחית את הצורך בשכבות הגנה מתקדמות בתוך הרשת הפנימית.
- ג. מכיוון השותף העסקי תמיד מפעיל מערכות הגנה חזקות יותר מהבנק בתוך הרשת הפנימית שלו, ולכן נדרש להעביר אותו דרך DMZ.
- ד. כי לא ניתן להגדיר יותר מרשת פנימית אחת בבנק, ולכן כל רשת אחרת מוגדרת כאדומה אוטומטית.
- ה. מכיוון השותף העסקי תמיד מפעיל מערכות הגנה בתוך הרשת הפנימית שלו פחות יעילות מהבנק, ולכן נדרש להעביר אותו דרך DMZ.



שאלה מס' 8 (5 נק')

בנק דיסקונט מעוניין לאפשר ללקוחות בבית להתחבר לחשבונם מהמחשב האישי בבית, ולבצע פעולות כגון העברת כספים וקבלת מידע על יתרות. אילו עיקרון אבטחתי מורכב רצוי ליישם כך שגישה חיצונית לא תסכן את הרשת הפנימית של הבנק, בהתאם לעקרונות ה-DMZ?

- להציב שרתי Front-End ב־ DMZ ולהמשיך לשרתי הליבה רק אחרי סינון ואימות קפדניים.
- להשתמש רק בהצפנת SSL/TLS מול האתר, ללא צורך בבקרת תכנים בתוך הרשת של הבנק.
- לאפשר גישה מלאה מהאינטרנט אל שרתי הליבה של הבנק, תוך שימוש בחומת אש שמאפשרת העברת טרנזקציות שנראות לגיטימיות.
- לכוון את כל החיבורים ישירות למערכת הבנק המרכזית, בהנחה שחתימת אנטי-וירוס שמאפשרת גם זיהוי פוגען מסוג תולעת תספיק להגנה.
- לבסס את האבטחה על הפרדה לוגית בחומת אש יחידה, ללא הגנות נוספות, כדי לפשט את התפעול.

שאלה מס' 9 (5 נק')

בארכיטקטורת אבטחה חדשה, הבנק שוקל להשתמש בפתרון Dual Firewall. מהו היתרון המשמעותי ביותר בגישה זו, בהשוואה לפתרון המבוסס על חומת אש יחידה שמחולקת לוגית, כש חלק אחד לוגי מחובר אל מחוץ לארגון והחלק הלוגי השני מחובר פנימה לתוך הארגון.

- אפשרות להשתמש בשני ספקים/טכנולוגיות חומת אש שונות, כך שכישלון או חולשה של אחד לא תאפשר לתוקף לפרוץ בקלות לרשת הפנימית.
- צמצום דרמטי של עלויות הרישוי והתחזוקה.
- הקטנת כמות החומרה הנדרשת, שכן שני פיירוולים פיזיים חוסכים קונפיגורציה מורכבת.
- הצפנת התעבורה בכל השלבים הופכת למיותרת, כי יש פיירוול גם בחוץ וגם בפנים.
- יכולת זיהוי איומים אוטומטית בעזרת מנוע אנטי-וירוס מובנה בכל פיירוול, ללא צורך בעדכוני תוכנה תכופים.

שאלה מס' 10 (5 נק')

התוקף הצליח לנצל חולשה בחומת אש שמחברת DMZ אל מחוץ לארגון והשתלט עליו. אילו צעדים מורכבים יוכלו לסייע למנוע מהתוקף להגיע לשרתי הליבה, למרות שהשליטה בחומת אש כבר אבדה?

- הצבת מערכות הגנה נוספות (כגון IPS/IDS) מאחורי ה-DMZ שחוסמות תעבורה חשודה בדרכה פנימה.
- הגדרת כללי ניתוב (Routing) גמישים באותה חומת אש, כך שתשמש כמעגל הגנה בפני עצמה גם לאחר הפריצה.
- הגדרת כללי פתיחת פורטים (Ports) קשיחים באותה חומת אש, כך שתשמש כמעגל הגנה בפני עצמה גם לאחר הפריצה.
- הזנת סיסמאות חומת האש לתוך מערכת ניהול משתמשים פנימית שמגבילה את גישת התוקף להגדרות הציוד.
- מניעת גישה לשותפים עסקיים לחלוטין, על מנת להקטין את שטח התקיפה החיצוני.

שאלה מס' 11 (5 נק')

בארגון בסדר גודל של בנק דיסקונט, מהם השיקולים המרכזיים שיש לקחת בחשבון כאשר מחליטים אם לפרוס חומת אש נוספת בתוך הרשת הארגונית (Internal Firewall)?

- ניהול סיכונים המשלב הערכת השפעת מתקפה מוצלחת ב־DMZ, גודל התקציב העומד לרשות הבנק ורמת מורכבות התפעול שבנק מוכן להכיל.
- העלות הכוללת של רכישת חומרה ותשלום לעובדים, מבלי להתייחס להערכת סיכונים של הבנק.
- הרצון להשאיר את כל שכבות האבטחה באותו שרת פיזי, לצמצום הזמני תגובה בעת אירועים.
- היכולת לאפשר לכל גורם שמתחבר ל־DMZ לגשת אוטומטית גם לרשת הפנימית לצורך מענה מהיר ללקוחות.
- חשש שדווקא הפיירוול הפנימי יכשיל לחלוטין את יכולת הסינון ב־DMZ החיצוני.



4 השאלות הבאות מתייחסות לנתונים הבאים:

חברת "ID-SecureTech" היא חברת הייטק גלובלית המתמחה בפתרונות ניהול זהויות בארגונים גדולים. החברה מספקת מערכות ותהליכים חכמים המשלבים אוטומציה ובינה מלאכותית כדי לאפשר ללקוחותיה להגן על משאבי המידע שלהם מפני איומי סייבר הן מבית (Insider Threat) והן מחוץ. בין לקוחות החברה נמנים בנקים, מוסדות בריאות, וחברות לוגיסטיקה ברחבי העולם.

שאלה מס' 12 (5 נק')

בארגון גדול שעובר לנהל הרשאות בשיטת RBAC (Role-Based Access Control) מתגלה שהרשאות של עובדים רבים לא נסגרו כראוי לאחר שעזבו תפקידים קודמים. איזה פתרון הכי נכון ליישם על-מנת למנוע הצטברות הרשאות עודפות לאורך זמן?

- להגדיר תהליכי אוטומציה שיבטלו הרשאות באופן דינמי כשעובד משנה תפקיד או עוזב, בשילוב בקרת מנהלים.
- לחייב את כל העובדים להחליף סיסמה אחת לשבוע בלבד, ללא קשר לשינוי בתפקיד.
- לאפשר רק למנהלי הפרויקט להעניק הרשאות ולהימנע מכל תהליך אוטומטי.
- לנהל תהליך Onboarding מוגדר היטב אבל לוותר על תהליך Offboarding כדי להימנע מטעויות.
- להפקיד את נושא ההרשאות אך ורק בידי מחלקת משאבי אנוש, כיוון שהיא היחידה שמכירה את סטטוס העובדים.

שאלה מס' 13 (5 נק')

בחברת "ID-SecureTech" יושם אימות רב-שלבי (MFA) המבוסס בין היתר על סיסמה רגילה ואס-אם-אס חד-פעמי. לפתע, כמה עובדים בכירים התלוננו על פעולות שלא ביצעו בחשבונם העסקי. מהו ההסבר הסביר ביותר לכישלון מנגנון האימות הזה?

- התוקף הצליח להשיג את קוד החד פעמי שמגיע בהודעת SMS לתיבת הודעות בטלפון האישי.
- המשתמשים כנראה הקלידו את הסיסמה בצורה שגויה במשך יותר משלושה ניסיונות.
- שומר בכניסה לארגון התיר לעובדים להיכנס ללא כרטיס עובד בתום שעות הפעילות.
- ייתכן שנפרצו כרטיסי הזדהות חכמים של העובדים לפני שהספיקו להיכנס למשרד.
- אחד השרתים נפגע פיזית בתאונת דרכים ונשללה גישת האימות מכל המשתמשים.

שאלה מס' 14 (5 נק')

במסגרת ייעוץ ללקוח בסקטור הבריאות, ביקש הלקוח פתרון לנעילת חשבונות של עובדי בית חולים הנמצאים בחופשת לידה או בחל"ת (חופשה ללא תשלום) לתקופה של חצי שנה, אך הוא חושש מעומס על מחלקת ה-IT. כיצד היית ממליץ ליישם זאת?

- להיעזר במנגנון אוטומטי שמזהה שינוי בסטטוס השכר (תלוש משכורת) או בסטטוס HR, ומבצע ניתוק זמני של ההרשאות עד לחזרה רשמית.
- לנעול ידנית כל חשבון עובדים בחל"ת, ולחדש את הרשאותיו רק אחרי פנייה רשמית למנכ"ל.
- לפתוח חשבון "כללי" ולשתף בו את העובדים שנמצאים בחל"ת, כדי שהרשאות לא יישכחו.
- לחייב את העובד בחל"ת לבצע התחברות יומית מהבית כדי לשמור את החשבון פעיל.
- לשנות את כל הסיסמאות בארגון מדי שבוע, כך שהעובד יחזור למציאות הרמונית מיד עם שובו.

שאלה מס' 15 (5 נק')

בחברה שבה נהוגות הסמכות והאחריות לניהול זהויות בידי מחלקת ה-IT בלבד, זוהתה חדירה פנימית של עובד זועם רגע לפני פיטוריו, אשר ניצל הרשאה למאגר פיננסי רגיש. איזה לקח הכי רלוונטי ליישם כדי לצמצם את סיכון ה-Insider Threat?

- לשלב בין ניהול הרשאות מרכזי במחלקת ה-IT לבין מנגנון בקרה של ה-CISO תוך קבלת עדכונים ממערכת משאבי האנוש (לדוגמה, בזמן שימוע לפני פיטורים).
- להעביר את כל ניהול ההרשאות לתחום אחריותו של מנהל משאבי אנוש בלבד.
- לבטל את גישת כל המנהלים למידע פיננסי על-ידי חסימת כל ההרשאות לכל העובדים, למעט מנכ"ל.
- לתעד את כל הפעילות הפיננסית בקובץ Excel בשרת משותף, כדי שהכול יהיה שקוף לכלל החברה.
- לחייב כל עובד למלא טופס "אין לי כוונות זדון" בחתימה דיגיטלית אחת לחודש.



5 השאלות הבאות מתייחסות לנתונים הבאים:

בית החולים "מרכז רפואי לב השרון" החליט לשדרג את תשתיות אבטחת המידע שלו עקב עליה בניסיונות פריצה לאזורי שירות מקוונים. בבית החולים מערכת מידע מרכזית המכילה מידע רגיש על המטופלים (תיק רפואי ממוחשב, תוצאות בדיקות, היסטוריית טיפולים ועוד). בנוסף, לבית החולים יש פורטל חיצוני המספק שירותי אונליין למטופלים כגון אפשרות לזימון תורים, העלאת מסמכים רפואיים ואזור תקשורת עם רופאים מרחוק.

שאלה מס' 16 (5 נק')

בבית החולים שוקלים לעבור ממודל IDS בלבד למודל IPS. אילו שיקולים מהותיים צריכים להנחות את מנהל אבטחת המידע בהחלטה האם לעבור למודל פעיל (Prevention) עבור כל סוגי ההתראות?

א. חשש מפגיעה בפעילות רפואית קריטית עקב חסימת שווא (False Positive) מול רווח היכולת לבלום תקיפות בזמן אמת.

ב. דרישות חוקיות המחייבות שימוש בחתימות מבוססות יצרן בלבד.

ג. הגדרת VLAN ייעודי למערכות חיצוניות תפתור אוטומטית את בעיית החסימות המוטעות.

ד. יצירת ממשקי API מאובטחים תייתר לחלוטין את הצורך בהגדרות מניעה אוטומטיות.

ה. שימוש גורף במערכות מבוססות התנהגות (Behavior-based) בלבד, בלי להפעיל מנגנון של חתימות.

שאלה מס' 17 (5 נק')

צוות ה IT מתכנן לפרוס שרת דוא"ל חיצוני ב DMZ כך שיקבל וימין קבצים מצורפים (תמונות, קבצי PDF וכדומה) לפני כניסתם לרשת הפנימית. מהי הסיבה המרכזית להחלטה זו, בהקשר שמירה על אבטחה מקסימלית?

א. בידוד ראשוני (סינון וסניטציה) של קבצים באיזור מפורז, כך שאם תהיה נזקה, היא לא תתפשט למערכות הקריטיות.

ב. שיפור זמני הטעינה של קבצים מצורפים באמצעות איזון עומסים חיצוני.

ג. מניעת יציאת מיילים לארכיון בטעות.

ד. הקטנת רוחב הפס הנדרש לרשת הפנימית של בית החולים.

ה. צמצום הצורך בניהול משתמשים חיצוניים באמצעות מערכות זיהוי כפול (2FA).

שאלה מס' 18 (5 נק')

בבית החולים מפעילים שני סוגים של מערכות IDS, האחת Network-based IDS (NIDS) המותקנת בין ה DMZ לרשת הפנימית, והשנייה Host-based IDS (HIDS) על שרתים קריטיים. באיזה מצב תהיה לחיבור המשולב של שתי המערכות תרומה משמעותית במיוחד לאבטחת המידע?

א. כשנדרש לזהות גם תקיפות מבוססות התנהגות (אנומליות) ברשת וגם שינויים בקבצי מערכת ליבתיים על שרתי המידע.

ב. כאשר יש צורך לאתר פגיעויות פיזיות בחומרה כדי לעצור נזק חשמלי לשרת.

ג. כשהמטרה היא לחסום גישה לגלישה באינטרנט מעמדות אחיות ומטופלים.

ד. לאתר בעיקר ניסיונות Brute Force על פורטי SSH דרך ניטור ברמת מערכת ההפעלה בלבד.

ה. כשמשתמשי בית החולים מתקינים תוכנות מרובות מהאינטרנט באופן חוקי וללא הגבלה.

שאלה מס' 19 (5 נק')

במחלקת המחקר של בית החולים מתכננים לקלוט נתונים מחברות ביוטק חיצוניות, העלולים להכיל מידע רגיש ולא סטנדרטי (למשל, פורמטים רפואיים מותאמים). אילו אמצעים יסייעו להפחית באופן יעיל את הסיכון להחדרת קוד זדוני דרך קבצים מיוחדים אלה?

א. שילוב ניתוח התנהגותי (Behavior-based) וסריקה מבוססת חתימות באיזור ה DMZ לפני שמעבירים את הקבצים לרשת הפנימית.

ב. שימוש בחומת אש על בסיס פתיחת פורטים ייעודיים בלבד.

ג. הגבלת גודל הקובץ המועבר למקסימום MB10.

ד. חלוקה של הרשת הפנימית לעוד שני תתי DMZ בתוך המבנה הקיים, ללא כלים נלווים.

ה. התקנת אנטי-וירוס סטנדרטי על תחנות הקצה של חוקרי הנתונים בלבד.



שאלה מס' 20 (5 נק')

לאחר הטמעת NGFW (חומת אש מדור חדש) והגדרת DMZ, בית החולים רוצה למנוע ניצול אפשרי של פרוטוקולים מותרים (כמו HTTPS או SMTP) לצורך החדרת נזקות מתוחכמות. כיצד כדאי לממש את חומת האש, על מנת לצמצם משמעותית את הסיכון?

א. להשתמש ביכולות Deep Packet Inspection (DPI) ובסינון אפליקטיבי, כך שגם בתוך פורט/פרוטוקול מותר, המערכת בוחנת את תוכן החבילה.

ב. לקבוע שהחומת אש תסנן רק את כתובות ה IP ותתעלם מתוכן החבילות, כדי לא לפגוע בביצועים.

ג. להתקין חומת אש נוספת פיזית לגמרי נפרדת, המוקדשת ספציפית אך ורק לסינון פרוטוקול התומך דואר אלקטרוני.

ד. לבטל את השימוש בהצפנה ולחייב שימוש בפרוטוקול HTTP רגיל כדי לאפשר צפייה נוחה בכל החבילות.

ה. להוריד עדכוני תוכנה רק פעם בשנה, כדי לשמור על יציבות הגדרות חומת אש.

